

במפגש השישי של הקורס "ניהול הגנת סייבר בארגון", המרצה מיכאל ציין כי הקורס הגיע למחצית הדרך (מפגש 6 מתוך 13) והתמקד בהמשך עולם **ניהול הסיכונים**, ניתוח אירוע בוחן (Case Study) של בית החולים הלל יפה, וסקירת מתודולוגיות ותקנים בינלאומיים 1. להלן סיכום הנושאים המרכזיים מהשיעור:

1. הערכת סיכונים וניהולם

הבסיס לניהול סיכונים הוא טבלה המצליבה בין שני משתנים: **ההסתברות** שהסיכון יתממש לעומת **האימפקט** (ההשפעה) שלו על המערכת 1-3.

- **אסטרטגיות התמודדות:** ארגון יכול לבחור לצמצם את הסיכון, להעבירו לצד שלישי (כמו שימוש ב-Firewall של חברה חיצונית), להימנע ממנו, או פשוט לקבל אותו אם עלות הטיפול בו גבוהה מהנזק הפוטנציאלי 3.
- **מיפוי נכסים:** חיוני להגדיר מהם הנכסים הקריטיים לארגון (ברמה העסקית והאישית) כדי לתת להם עדיפות בהגנה ובתוכניות התאוששות מאסון (BCP/DRP) 4, 5.

2. ניתוח אירוע: פריצת הסייבר לבית החולים "הלל יפה" (2021)

המרצה השתמש במקרה זה כדי להדגים כשלים בניהול סיכונים 5:

- **הקשר:** תקופת הקורונה האיצה טרנספורמציה דיגיטלית (קביעת תורים באפליקציה, עבודה מרחוק), מה שהגדיל משמעותית את "שטח התקיפה" ואת כמות המידע הרגיש ברשת 5, 6.
- **המתקפה:** מתקפת כופר שהחלה בפיישינג (Phishing) מתוחכם. המערכות הקריטיות הושבתו והצוות עבר לעבודה ידנית 7.
- **כשלים בהתאוששות:** תהליך החזרה לשגרה לקח שבועות כי לא הוודא שהמערכת נקייה לגמרי לפני שהועלתה מחדש, וחלק מהגיבויים עצמם היו נגועים מכיוון שהתוקפים שהו ברשת זמן רב לפני הפריצה 7, 8.
- **מסקנות:** צורך בסיגמנטציה (הפרדת רשתות), אימוץ מודל **Zero Trust**, עדכוני תוכנה שוטפים והדרכת עובדים 8, 9.

3. שיטות לניתוח בעיות וקבלת החלטות

בשיעור הוצגו מספר כלים ניהוליים לניתוח "שורש הבעיה" (Root Cause Analysis):

- **5 ה-Whys:** שאילת "למה" חמש פעמים כדי להגיע למקור הבעיה (שיטה שהגיעה מטיוטה) 9, 10.
- **ששת הכובעים של בוננו:** ניתוח בעיה משש נקודות מבט שונות (עובדות, רגש, חשיבה שלילית/ביקורתית, אופטימיות, יצירתיות ושלטת) 10.
- **שיטת MoSCoW:** תיעוד ותיעוד דרישות לפי סדר חשיבות: **Must have** (חובה), **Should have** (צריך), **Could have** (יכול להיות נחמד) ו-**Won't have** (לא יהיה בשלב זה) 11, 12.

4. תקנים ומתודולוגיות בינלאומיות (Frameworks)

ה-CISO נדרש להכיר מגוון תקנים לניהול אבטחת מידע 12:

- **NIST CSF:** מסגרת עבודה אמריקאית מובנית הכוללת זיהוי, הגנה, זיהוי איומים, תגובה והתאוששות 12.
- **ISO (27001, 27005):** תקנים בינלאומיים המגדירים תהליכי ניהול סיכונים ובקורות אבטחה, המשמשים לעתים קרובות לצורך ביקורות חיצוניות 13, 14.
- **SOC 2:** תקן נפוץ לחברות טכנולוגיה המאשר שהן עומדות בקריטריונים של אבטחה, פרטיות וזמינות 15.
- **FAIR:** מודל כמותי המתמקד בניתוח הפסדים כספיים ופגיעה במוניטין בעקבות מתקפת סייבר 15.
- **COBIT:** מודל המתמקד בממשל IT ובקשר בין יעדי אבטחה ליעדים עסקיים, נפוץ בארגונים פיננסיים גדולים 16.

- **RMF**: מסגרת לניהול סיכונים המתחברת ל-NIST, משמשת בעיקר גופים פדרליים וביטחוניים (כמו ה-FBI) הדורשים רמות אבטחה מחמירות במיוחד (17 FedRAMP).
לסיכום: המרצה הדגיש כי רוב הפריצות נובעות ממוצרים שנבנו מראש בצורה לא מאובטחת או מפערים בין מה שהלקוח היה צריך לבין מה שנבנה בפועל 4, 18. לכן, ניהול סיכונים מתמיד הוא קריטי לשמירה על חוסן הארגון 17.